COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.3 · Data Types & Classifications

Mestre CyberSec · **Aula 3.3 — Data Types & Classifications** (5:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Classificar o dado: PUBLIC (nada perde); INTERNAL (apenas dentro); CONFIDENTIAL (estratégia, PII — fuga = dano grave); RESTRICTED (trade secret — fuga=catastrófico). A classificação DETERMINA o controle. PHI=dado de saúde; PCI-DSS=cartão.

💡 Highlights que a prova CompTIA cobra

- Classificação determina QUAL proteção cada dado recebe
- PHI = saúde; PCI-DSS = cartão; PII = dados pessoais

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'least restrictive classification'=public; 'most restrictive'=restricted

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.3 — Data Types & Classifications)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Dados Públicos (N/A)

Informação aprovada para divulgação a qualquer pessoa, sem expectativa de confidencialidade; a divulgação não causa dano.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'least restrictive classification' = Public. Se puder ser compartilhado livremente, é Public.*

• Dados Internos (N/A)

Informação destinada apenas ao uso interno da organização; a divulgação não autorizada pode causar dano operacional ou reputacional limitado.

⚠ ***Armadilha CompTIA:*** *Gatilho: uso apenas dentro da empresa, nem público nem altamente sensível. Não confundir com Public.*

• Dados Confidenciais (N/A)

Informação sensível como estratégia de negócio ou PII; a divulgação não autorizada pode causar dano grave à organização ou a indivíduos.

⚠ ***Armadilha CompTIA:*** *Gatilho: PII, estratégia, planos internos = Confidential. Fuga gera dano grave.*

• Dados Restritos (N/A)

Classificação mais sensível, incluindo segredos comerciais; a divulgação não autorizada causa dano catastrófico e exige os controles mais rígidos.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'most restrictive classification' = Restricted. Trade secret/fuga catastrófica = Restricted.*

• Informações de Identificação Pessoal (PII)

Dados que podem identificar um indivíduo específico, como nome, CPF/SSN ou biometria; geralmente classificados como Confidential e protegidos por leis de privacidade.

⚠ ***Armadilha CompTIA:*** *Gatilho: PII = dados pessoais; se vazar, geralmente é Confidential com dano grave.*

• Informações de Saúde Protegidas (PHI)

Informação de saúde que identifica um indivíduo e é protegida por regulamentações como HIPAA; exige controles rigorosos de privacidade e segurança.

⚠️ ***Armadilha CompTIA:*** *Gatilho: PHI = dado de saúde. Se a questão citar HIPAA ou prontuário, pense PHI.*

• Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)
Padrão de segurança para organizações que armazenam, processam ou transmitem dados de cartão; a não conformidade pode gerar multas e perda de processamento de pagamentos.

⚠️ ***Armadilha CompTIA:*** *Gatilho: PCI-DSS = cartão/cardholder data. Não é uma classificação, é um padrão de compliance.*

• Classificação de Dados (N/A)
Processo de rotular dados com base na sensibilidade e valor para que controles de segurança e procedimentos de manuseio apropriados sejam aplicados.

⚠️ ***Armadilha CompTIA:*** *Gatilho: a classificação DETERMINA o controle. Primeiro classifique, depois aplique proteção proporcional.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Níveis de Classificação de Dados Corporativos (Public, Internal, Confidential, Restricted)

🏠 **Analogia Intuitiva:** Pense no sistema de correspondência e circulação de um edifício comercial de luxo. Os panfletos e folhetos de propaganda na recepção são de acesso 'Público' (qualquer transeunte pode pegar e levar). O mural de avisos da copa dos funcionários com a escala de limpeza e ramais de ramal é 'Interno' (não é um segredo de Estado, mas não deve ser jogado na rua). Os contratos de locação de salas e balanços de despesas guardados no armário da administração com chave são 'Confidenciais' (se vazarem, geram processos e prejuízo financeiro). Por fim, o projeto dos dutos de ar, a planta dos cofres e a chave-mestra do prédio são 'Restritos/Secretos' (acessíveis apenas à diretoria executiva; se caírem em mãos erradas, ameaçam a própria sobrevivência física e operacional do edifício).

🔍 **Causa Raiz / Por que foi criado:** Vazamentos devastadores ocorrem quando as organizações tratam todos os dados de forma idêntica, sem saber onde estão os arquivos mais perigosos, ou caem na armadilha da sobreclassificação — marcando tudo como 'ultrassecreto', o que paralisa as operações diárias e empurra os colaboradores para ferramentas não homologadas de Shadow IT.

🛡️ **Visão do Auditor de GRC:** O auditor exige uma Política Formal de Classificação de Dados com papéis estritos: Data Owner (define o nível de sensibilidade e aprova acessos) e Data Custodian (aplica os controles técnicos de armazenamento e backup). Fiscaliza também rotulagem obrigatória (metadados e marcas d'água) e treinamento de conscientização periódico.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'least restrictive classification level' = Public (dano zero em caso de vazamento). 'Highest impact to organizational survival/catastrophic damage' = Restricted / Secret / Top Secret. Pegadinha clássica: diferenciar os esquemas governamentais/militares (Unclassified, Confidential, Secret, Top Secret) do esquema corporativo privado (Public, Internal, Confidential, Restricted).

📌 PII (Personally Identifiable Information) vs PHI (Protected Health Information)

🏠 **Analogia Intuitiva:** Seu documento de identidade e CPF esquecidos no balcão de uma loja são PII: eles identificam você como cidadão perante o governo e o comércio. Já o seu prontuário médico lacrado com exame de sangue, histórico psiquiátrico e biópsia guardado no hospital é PHI: ele não apenas diz quem você é, mas expõe as intimidades mais profundas da sua biologia humana e vulnerabilidade corporal.

🔍 **Causa Raiz / Por que foi criado:** A facilidade de combinar bancos de dados digitais permite que criminosos cometem roubo de identidade e fraudes financeiras com PII, enquanto registros médicos (PHI) alcançam valores dez vezes maiores na dark web por serem permanentes e permitirem fraudes complexas de seguros e chantagem.

🛡️ **Visão do Auditor de GRC:** Auditoria de conformidade com marcos de privacidade globais: LGPD (Brasil) e GDPR (Europa) para PII, exigindo Relatório de Impacto à Proteção de Dados (DPIA/RIPD) e direito de esquecimento; e HIPAA/HITECH (EUA) para PHI, exigindo trilhas imutáveis de acesso a prontuários e criptografia ponta a ponta.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'patient diagnosis, lab results, medical billing, doctor notes' = PHI (regulamentado por HIPAA). Gatilho: 'social security number, biometric identifier, home address, passport number' = PII. Lembre-se: todo PHI é um subconjunto de PII, mas protegido por leis de saúde específicas.

📌 Propriedade Intelectual (Intellectual Property - IP) e Segredos Industriais

🏠 **Analogia Intuitiva:** A fórmula ultrassecreta do xarope da Coca-Cola mantida em um cofre no subsolo em Atlanta, ou as plantas aerodinâmicas e o código de telemetria de um motor de Fórmula 1. Se um concorrente copiar esse projeto, a empresa perde instantaneamente sua vantagem competitiva de bilhões de dólares construída ao longo de décadas.

🔍 **Causa Raiz / Por que foi criado:** A facilidade de copiar gigabytes de código-fonte, patentes e esquemas industriais em um miniflash drive de 2 segundos ou anexar a um e-mail pessoal por ex-funcionários descontentes (insider threat) ou espiões corporativos contratados.

🛡️ **Visão do Auditor de GRC:** Fiscalização de acordos de não divulgação (NDAs), cláusulas de propriedade intelectual em contratos de trabalho, revogação imediata de credenciais no desligamento (offboarding seguro), e isolamento em rede fechada (Air Gap ou VLAN isolada) de repositórios de P&D (Pesquisa e Desenvolvimento).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'trade secrets, patented designs, engineering schematics, proprietary software source code that provide competitive advantage' = Intellectual Property (IP). Distrator: não confundir com PII pública.

📌 Dados Financeiros e o Padrão PCI-DSS (Cardholder Data)

🏠 **Analogia Intuitiva:** A máquina de cartão de crédito e a via do recibo em uma loja. A loja tem direito de receber o valor da sua compra, mas se o balconista pegar um caderninho e anotar o número completo do seu cartão de crédito (PAN) e aquele código de 3 dígitos do verso (CVV/CVC), ele está cometendo uma violação gravíssima passível de cancelamento imediato da loja e processo criminal.

🔍 **Causa Raiz / Por que foi criado:** A epidemia global de clonagem de cartões e fraudes de compras virtuais sem cartão presente (Card Not Present - CNP), que fez as operadoras de cartão criarem um padrão rigoroso unificado para punir lojistas negligentes com multas milionárias.

🛡️ **Visão do Auditor de GRC:** Avaliação de conformidade com o PCI-DSS (Payment Card Industry Data Security Standard); auditoria de segmentação do Ambiente de Dados do Portador do Cartão (CDE - Cardholder Data Environment) com firewalls; e fiscalização da REGRA DE OURO: o código CVV/CVC jamais pode ser salvo em repouso após a autorização da transação.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'organization processes, stores, or transmits credit card numbers (PAN), expiration dates, and cardholder data' = PCI-DSS. Pegadinha absoluta de prova: se a questão perguntar qual dado NUNCA pode ser armazenado em repouso, a resposta é o CVV/CVC (Card Verification Code) ou dados de trilha magnética.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Divulgação pública intencional de folhetos comerciais ou comunicados de imprensa sem dano à empresa	**Dados Públicos (Public Data)**
Vazamento de tabelas salariais internas e organogramas operacionais que causaria constrangimento e atrito interno	**Dados Internos (Internal / Private Data)**
Vazamento de relatórios contábeis prévios, contratos comerciais e dados de clientes que causaria dano financeiro e judicial grave	**Dados Confidenciais (Confidential Data)**
Vazamento de algoritmos proprietários de alta frequência, projetos militares ou chaves-mestras criptográficas que ameaçam a sobrevivência da organização	**Dados Restritos / Secretos (Restricted / Secret Data)**
Registros de prontuários clínicos, diagnósticos médicos de pacientes e laudos de biópsia protegidos por lei sanitária	**Informações de Saúde Protegidas (PHI - HIPAA)**
Número de CPF/SSN, endereço residencial, data de nascimento e identificador biométrico de cidadãos protegidos por leis de privacidade	**Informações de Identificação Pessoal (PII - GDPR/LGPD)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital armazena nomes de pacientes, diagnósticos, históricos de medicação e identificadores de seguro em um sistema de prontuários clínicos. A equipe de segurança deve documentar o tipo de dado regulamentado representado por esse conjunto. Qual tipo de dado é?

A) Dados públicos em todos os ambientes corporativos em nuvem

B) Informações de identificação pessoal (PII)

C) Informações de saúde protegidas (PHI)

D) Dados de cartão de pagamento em todos os clusters corporativos internos

QUESTÃO 2 · CENÁRIO DE EXAME

Um sistema de RH contém números de Seguro Social, endereços residenciais, datas de nascimento e detalhes de contato de emergência de funcionários. Qual tipo de dado é representado?

A) Informações de identificação pessoal (PII)

B) Dados públicos para preservar a integridade do payload e da topologia

C) Informações de saúde protegidas (PHI) em todos os clusters corporativos internos

D) Dados de cartão de pagamento durante janelas agendadas de manutenção administrativa

QUESTÃO 3 · CENÁRIO DE EXAME

Um aplicativo de pagamento de varejo processa números de conta principal, datas de validade e códigos de serviço de clientes durante o checkout. Qual tipo de dado regulamentado se aplica a essas informações?

A) Informações de identificação pessoal (PII) para preservar a integridade do payload e da topologia

B) Dados do Payment Card Industry Data Security Standard (PCI-DSS)

C) Informações de saúde protegidas (PHI) durante janelas agendadas de manutenção administrativa

D) Dados públicos antes de encaminhar requisições aos serviços backend

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa publica seu relatório anual de sustentabilidade em um site acessível externamente para que qualquer pessoa possa baixá-lo sem autenticação. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse relatório deve ser classificado?

A) Interno

B) Confidencial

C) Restrito

D) Público

QUESTÃO 5 · CENÁRIO DE EXAME

Um diretório de nomes de funcionários e ramais de trabalho é acessível apenas pela rede corporativa e não é compartilhado com clientes, fornecedores ou o público. Como esse diretório deve ser classificado sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito?

A) Interno

B) Público antes de encaminhar requisições aos serviços backend

C) Confidencial

D) Restrito

QUESTÃO 6 · CENÁRIO DE EXAME

Um banco de dados de marketing contém nomes de clientes, endereços de e-mail, históricos de pedidos e números de contas de fidelidade. A divulgação não autorizada causaria dano reputacional e regulatório grave à empresa. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse banco de dados deve ser classificado?

A) Público antes de encaminhar requisições aos serviços backend

B) Interno aplicando políticas rigorosas de menor privilégio

C) Confidencial

D) Restrito para garantir alta disponibilidade contínua e conformidade

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa de tecnologia armazena código-fonte e documentos de design de um produto não lançado que usa algoritmos proprietários. A divulgação daria grande vantagem a concorrentes e causaria perda financeira catastrófica. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse material deve ser classificado?

A) Público aplicando políticas rigorosas de menor privilégio

B) Interno eliminando pontos únicos de falha entre endpoints

C) Confidencial

D) Restrito

QUESTÃO 8 · CENÁRIO DE EXAME

Um funcionário precisa compartilhar um memorando com um consultor externo. O memorando está atualmente rotulado apenas para uso interno e não contém PII, PHI, dados de cartão de pagamento ou segredos comerciais. De acordo com o tratamento orientado pela classificação, o que o funcionário deve fazer primeiro?

A) Enviá-lo ao site público e mandar a URL ao consultor

B) Solicitar uma exceção de política ou reclassificação antes de compartilhá-lo externamente

C) Criptografá-lo com uma senha pessoal e enviá-lo de uma conta de e-mail pessoal

D) Publicá-lo no site de colaboração interna e dar ao consultor uma conta VPN

QUESTÃO 9 · CENÁRIO DE EXAME

Um hospital precisa enviar informações de saúde protegidas a um fornecedor de cobrança para processamento de sinistros. Qual conjunto de controles melhor se alinha à classificação e aos requisitos regulatórios do dado?

A) Usar transferência criptografada, acordo de associado de negócios, acesso de menor privilégio e registro de auditoria

B) Rotular os dados como públicos e publicá-los em um portal público para download pelo fornecedor em todos os perímetros da zona desmilitarizada

C) Converter os dados em PDF e enviá-los por e-mail comum sem criptografia em todos os ambientes corporativos em nuvem

D) Armazenar os dados em um compartilhamento interno e dar ao fornecedor uma conta local compartilhada sem alterar as regras existentes de firewall

QUESTÃO 10 · CENÁRIO DE EXAME

Um bucket de armazenamento em nuvem contém PDFs de marketing liberáveis publicamente, documentos de políticas internas e registros de contas de clientes com PII. A equipe de segurança deve aplicar a política de classificação de dados da empresa ao conteúdo do bucket. Qual abordagem é mais apropriada?

A) Rotular o bucket inteiro como público porque alguns arquivos são seguros para divulgação em todos os perímetros da zona desmilitarizada

B) Rotular o bucket inteiro como confidencial porque alguns arquivos contêm PII em todos os ambientes corporativos em nuvem

C) Criptografar o bucket uma vez e dar acesso a todos os funcionários para simplificar o gerenciamento sem alterar as regras existentes de firewall

D) Aplicar rótulos de classificação por objeto e impor controles de acesso e DLP com base em cada rótulo

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Informações de saúde protegidas (PHI)

Correto: PHI. O conjunto combina informações de saúde com identificadores, portanto são informações de saúde protegidas pela HIPAA. PII é um termo mais amplo para dados pessoais, mas não aborda especificamente informações de tratamento de saúde; dados públicos e dados de cartão de pagamento estão incorretos porque os registros não são compartilháveis abertamente nem dados de cartão.

Questão 2: Alternativa A — Informações de identificação pessoal (PII)

Correto: PII. Esses campos podem identificar um indivíduo específico e exigem proteção. PHI se aplica a informações de saúde, dados de cartão de pagamento se aplicam a dados de portadores de cartão, e dados públicos não exigiriam controles de privacidade.

Questão 3: Alternativa B — Dados do Payment Card Industry Data Security Standard (PCI-DSS)

Correto: dados PCI-DSS. Dados de portador de cartão, como PAN, data de validade e código de serviço, são regidos pelo PCI-DSS. PII e PHI são categorias regulamentadas diferentes, e dados públicos não têm esses requisitos de proteção.

Questão 4: Alternativa D — Público

Correto: Público. O dado destina-se à divulgação aberta e sua exposição não causa dano. Dados internos não são para divulgação externa, dados confidenciais causariam dano grave se expostos, e dados restritos causariam dano catastrófico.

Questão 5: Alternativa A — Interno

Correto: Interno. Ele apoia operações internas e deve permanecer dentro da organização, mas sua exposição não causaria dano grave ou catastrófico. Público permitiria divulgação aberta, enquanto Confidencial e Restrito exigem proteção mais forte.

Questão 6: Alternativa C — Confidencial

Correto: Confidencial. PII de clientes e dados relacionados a contas geralmente exigem proteção porque a exposição causa dano grave. Restrito é reservado para segredos comerciais ou dados cuja perda é catastrófica. Público e Interno não se aplicam porque os dados são sensíveis e não meramente informações operacionais internas.

Questão 7: Alternativa D — Restrito

Correto: Restrito. O material é um segredo comercial cuja exposição causaria dano catastrófico. Confidencial cobre dano grave, como exposição de PII, enquanto Interno e Público forneceriam proteção muito inferior.

Questão 8: Alternativa B — Solicitar uma exceção de política ou reclassificação antes de compartilhá-lo externamente

Correto: Solicitar uma exceção de política ou reclassificação. Dados internos destinam-se ao uso interno, então o compartilhamento externo exige aprovação e possivelmente um novo rótulo com controles apropriados. Publicação pública é não autorizada, e-mail pessoal contorna a política, e dar acesso VPN a terceiro altera o acesso sem tratar a classificação.

Questão 9: Alternativa A — Usar transferência criptografada, acordo de associado de negócios, acesso de menor privilégio e registro de auditoria

Correto: Usar transferência criptografada, BAA, acesso de menor privilégio e registro de auditoria. PHI é regulamentada e altamente sensível, portanto exige fortes salvaguardas técnicas e administrativas. Publicação pública, e-mail não criptografado e contas locais compartilhadas expõem os dados e violam expectativas da HIPAA.

Questão 10: Alternativa D — Aplicar rótulos de classificação por objeto e impor controles de acesso e DLP com base em cada rótulo

Correto: Aplicar rótulos de classificação por objeto e impor controles com base em cada rótulo. Um bucket misto não pode ser gerenciado com segurança com uma única classificação genérica. A rotulagem por objeto garante que dados públicos, internos e confidenciais recebam os controles apropriados de acesso, criptografia e monitoramento.